



STAFF OPERATING MANUAL

How the platform works, and your part in it

One platform runs the clinic: bookings, clients, payments, marketing, the academy and the website. This manual explains every part, what you do in your role, and what the owner must set up and keep compliant.

For
All clinic staff & the owner

Platform
kclinics.co.uk

Version
14 June 2026

WHAT'S INSIDE

01	How to use this manual	13	Administration
02	Signing in, your account and 2FA	14	The public website and booking flow
03	The admin at a glance	15	The kiosk and in-clinic screens
04	Today — dashboard, day and tasks	16	The client portal
05	Clients & Bookings	17	Consent, before-photos and clinical safety
06	Loyalty & Offers	18	Owner: APIs, tokens and webhooks
07	Catalogue — services and products	19	Owner: environment variables and secrets
08	Website	20	Owner: data retention
09	K Academy — the training platform	21	Owner: GDPR and data protection
10	Operations	22	Owner: security baseline
11	Marketing	23	On the roadmap
12	Finance	24	Glossary and where to get help

01 How to use this manual

Read the part for your role, keep the rest for reference. Every screen named here is reached from the left-hand menu in the admin at kclinics.co.uk/admin.

WHO THIS IS FOR

Everyone who works in the clinic uses the admin. What you can see and do depends on your role. The owner sets roles up. If a screen named here is not in your menu, your role does not have access to it — that is normal.

THE ROLE TAGS

Each instruction carries a tag showing who it is for. Tags are a guide; the owner can grant or remove individual permissions for any person.

Tag	Who it means
OWNER	You own the business. Full access, plus the security and money controls no one else has.
ADMIN	Manages day-to-day clinic operations. Almost everything except staff accounts, settings and security.
FRONT DESK	Reception. Booking, checking clients in, taking payment, answering calls and chat.
CLINICIAN	Practitioner or doctor. Appointments, client clinical records, consent, stock used in treatment.
ALL STAFF	Everyone with a login, whatever the role.
SOON	Planned feature, not live yet. Listed so you know it is coming.

HOW INSTRUCTIONS ARE WRITTEN

Numbered steps are one action each, naming the button or field exactly as it appears. A line starting "Done when:" tells you what success looks like, so you know you have finished.

GOLDEN RULE

Never share your login. Each person has their own account so the activity log shows who did what. If someone needs access, ask the owner to add them.

02 Signing in, your account and 2FA

Your login protects client and health data. Treat it the way you would treat keys to the clinic.

Sign in to the admin

ALL STAFF

- Go to kclinics.co.uk/admin.
- Enter your work email and password, then press **Sign in**.
- If asked for a 6-digit code, open your authenticator app and type the current code. If asked for Face ID or a fingerprint, follow the prompt on your device.

Done when: you land on the dashboard with your name in the greeting.

Turn on two-factor (2FA) for yourself

ALL STAFF

A second step at login so a stolen password is not enough to get in. The owner can require this for your role.

- Open </admin/security> (or ask the owner to send you the setup link).
- Choose **Authenticator app**, scan the square code with Google Authenticator or Authy, and enter the 6-digit code it shows.
- Save the **recovery codes** somewhere safe — they get you in if you lose your phone.

Done when: your security page shows 2FA as on.

Add Face ID or a fingerprint (passkey)

ALL STAFF

Sign in with your face or fingerprint instead of typing a password. Your password still works as a backup.

- On the device you use most, open </admin/security>.
- Press **Add passkey** and follow your device prompt (Face ID, Touch ID or Windows Hello).
- Name the device so you recognise it later.

Done when: the device is listed under your passkeys.

IF YOU ARE LOCKED OUT

Five wrong passwords locks the account for 15 minutes. The owner can unlock you straight away from `/admin/security`. After three wrong tries you may be asked to pass a quick "I am human" check.

PASSWORDS

- Use a long password you do not use anywhere else. A short memorable phrase of several words beats a single complex word.
- Never reuse your clinic password on personal sites.
- The owner should ask everyone to change passwords if a device is lost or a person leaves.

03 The admin at a glance

The left-hand menu groups every screen into ten sections. This manual follows that order. Below is the whole map and who each role can reach.

Menu group	What lives there
Today	Dashboard, My day, Calendar, Tasks, Time off
Clients & Bookings	Bookings, Waitlist, Consultations, Live chat, Calls, Clients, Reviews, NPS
Loyalty & Offers	Discounts, Promotions, Rewards, Membership, Gift vouchers
Catalogue	Services & pricing, Products
Website	Pages, Reusable blocks, Journal, Media, Before & after
K Academy	Courses, Applications, Trainees, Exam practice, Live classes, Careers
Operations	Schedules, Session insights, Inventory, Reorder, Suppliers, SOPs, Consent, Health forms, Devices, Day close, Facility
Marketing	Hub, Campaigns, Performance, Audiences, Email, Templates, Automations, A/B testing, Insights, Brand kit, Connections, QR codes
Finance	Till (POS), Orders, Cashflow, Reports, Financial controls
Administration	Go live, Status, API health, Build & issues, Contractors, Staff & access, Security, Activity log, Site & globals, Locations, SEO, Redirects, Integrations, Credentials, Settings

WHAT EACH ROLE CAN REACH

Role	Access
Owner	Everything, with no limits. Only the owner manages staff accounts, settings, security and the money controls.
Admin	All clinic operations and clinical records. Cannot manage staff, settings or security.
Clinician	Dashboard, calendar, bookings, clients and clinical records, consent, stock, day close, facility, the build board.
Front desk	Bookings and payments, consultations, clients (non-clinical), chat and calls, schedule, stock, the till, day close.
Developer	Dashboard, build board, platform status and API health only. No client or clinical data.
Contractor	Dashboard, facility documents and their assigned tasks only, plus clock in and out.
Staff	Read-only view of bookings, consultations, clients, calendar and stock, plus day close and facility.

REPORT A PROBLEM

See something broken or wrong on any screen? Use the small **Report a problem** button at the bottom-right of the page. It grabs a screenshot and files it on the Build & Issues board for the owner and the dev to pick up.

04 Today — dashboard, day and tasks

Your starting point each shift: what is happening today and what needs doing.

Screen	What it is for	For
Dashboard /admin	Your home screen. Greeting, live clock, weather, key numbers and the jobs that need attention. The layout shapes itself to your role.	All staff
My day /admin/my-day	Your personal agenda — your appointments, prep and tasks for today.	All staff
Calendar /admin/calendar	The whole day on a grid, every clinician side by side, 8am to 9pm. Add time blocks here.	Front desk, Clinician
Tasks /admin/tasks	Shared to-do board for the team. The menu shows a count of open tasks.	All staff
Time off /admin/time-off	Request and approve holiday, sick, training and personal time.	All staff

Clock in and out

ALL STAFF

1. On the dashboard, find the clock-in pill near the top.
2. Press it once when you start your shift, and again when you finish.

Done when: the pill shows you as clocked in, with the time.

Add a task for the team

ALL STAFF

1. Open </admin/tasks> and press **New task**.
2. Type a clear title, add detail, set a priority and a due date.
3. Pick an **Assignee** if it is for a specific person; link a client if it relates to one.
4. Press **Save**. The task appears in the Open column.

Done when: the task shows in Open with its reference (e.g. TSK-42) and assignee.

Request time off

ALL STAFF

1. Open </admin/time-off> and press **Request time off**.
2. Choose the type: Holiday, Sick, Training or Personal.
3. Pick the dates (all day, or a time range), add a short reason, and submit.

Done when: your request shows as Pending until an approver decides.

Approve or decline time off

ADMIN

OWNER

Approvers have a count of pending requests in the menu.

1. Open </admin/time-off>.
2. Open a request marked Pending, check the team calendar below it for clashes, and press **Approve** or **Decline**.

Done when: the request moves to Approved or Declined and the person is notified.

05 Clients & Bookings

Every appointment, every client record, and every way clients reach you — calls, chat and enquiries — in one place.

Screen	What it is for	For
Bookings /admin/bookings	The master appointment list. Filter by Upcoming, Requests, Past, Confirmed, Completed, Cancelled. Search by client or treatment.	Front desk, Clinician
Waitlist /admin/waitlist	Clients waiting for a slot. When a matching cancellation opens, they are offered it automatically.	Front desk
Consultations /admin/consultations	New enquiries from the website. Move each from New to Contacted to Booked.	Front desk
Live chat /admin/chat	Web chat, SMS and WhatsApp messages. The menu shows unread count.	Front desk
Calls /admin/calls	Phone log with recordings and transcripts; click a number to dial out.	Front desk
Clients /admin/clients	The full client database. Profiles, history, tags and (for clinicians) encrypted health records.	Front desk, Clinician
Reviews /admin/reviews	Approve and publish client reviews to the website.	Admin
NPS /admin/nps	Satisfaction score and survey replies over time.	Admin

Take a booking over the phone or desk

FRONT DESK

1. Open `/admin/bookings` and press **New booking**.
2. Search the client by name; if new, add them with name, phone and email.
3. Choose the treatment and variant (for example "Laser — underarms"), then a date and time from the free slots.
4. Pick the clinician if the client has a preference.
5. Confirm. Choose whether to take a card now or on the day, per clinic policy.

Done when: the appointment shows under Upcoming and the client gets a confirmation email.

Reschedule or cancel an appointment

FRONT DESK

1. Open `/admin/bookings`, find the appointment (search by name), and open it.
2. Press **Reschedule** and pick a new free slot, or press **Cancel** and choose a reason.

Done when: the new time shows, and the client is emailed the change.

Check a client in for their appointment

FRONT DESK

CLINICIAN

1. Open the client's appointment from `/admin/bookings` or the Calendar.
2. Confirm their health form and consent are complete (see Operations). If not, send the form before treatment.
3. Mark the appointment as arrived / in session.

Done when: the room display outside shows the room as in session.

Open a client's clinical record

CLINICIAN

Health data is encrypted and only opens for staff with clinical permission.

1. Open `/admin/clients` and search the client.
2. Open their profile and select the **Clinical** area to read allergies, medications and notes.
3. Add a treatment note after the appointment so the record stays current.

Done when: your note is saved against the client and dated.

CLIENT PRIVACY

Exporting or deleting a client is recorded in the activity log and limited to senior roles. Never download client lists to a personal device. See the GDPR section for the right way to handle access and erasure requests.

06 Loyalty & Offers

The tools that bring clients back: discount codes, timed promotions, points, memberships and gift cards.

Screen	What it is for	For
Discounts <code>/admin/discounts</code>	Create codes (percentage or fixed amount), set limits and expiry, and override welcome-offer claims.	Admin
Promotions <code>/admin/promotions</code>	Timed offers shown on the site and in client accounts.	Admin
Rewards <code>/admin/rewards</code>	Staff points and leaderboard — a motivation layer for the team, not for clients.	Admin, Owner
Membership <code>/admin/membership</code>	Subscription tiers and their benefits; see active members.	Admin
Gift vouchers <code>/admin/gift-vouchers</code>	Issue and track gift cards; check balances and expiry.	Front desk

Create a discount code

ADMIN

1. Open `/admin/discounts` and press **New code**.
2. Type the code, choose percentage or fixed amount, and set a usage limit and expiry date.
3. Save. Share the code, or add it to a campaign.

Done when: the code appears in the list and works at checkout.

Put an offer live on the site

ADMIN

1. Open `/admin/promotions` and press **New promotion**.
2. Set the headline, the offer, and start and end dates.
3. Save. It shows in the offers strip on the booking page while active.

Done when: the offer appears on `/offers` and on the booking page.

Clients earn points for spending and for leaving reviews, redeemable against future visits. Referrals give both people credit once the new client's first treatment is done. These run automatically; you only step in to fix a dispute.

07 Catalogue — services and products

Your treatment menu and your retail shelf. Prices set here flow to the website, the booking page and the till.

Screen	What it is for	For
Services & pricing /admin/services	Every treatment, its variants, price, cost, duration and VAT class. Bulk price changes and offers live here.	Admin
Products /admin/products	Retail stock — skincare and supplements. Prices, images, stock and 18+ flags.	Admin

Add or edit a treatment ADMIN

1. Open </admin/services> and pick the category, or press **New service**.
2. Set the name, price, cost of goods, duration and VAT class.
3. Add variants if the treatment has options (different areas or strengths), each with its own price and time.
4. Make sure **Active** is ticked so clients can book it. Save.

Done when: the treatment shows on the website and in the booking list at the right price.

Add a retail product ADMIN

1. Open </admin/products> and press **New product**.
2. Add the name, price, an image and the stock quantity.
3. Tick **18+** if it must be age-checked at checkout. Save.

Done when: the product shows in the shop and on the till.

08 Website

Build and edit the public site without code. The design is locked to the brand, so pages stay on-brand whoever edits them.

Screen	What it is for	For
Pages /admin/pages	The page builder. Drag on-brand sections to build landing and treatment pages.	Admin
Reusable blocks /admin/blocks	Build a section once and reuse it across many pages.	Admin
Journal /admin/journal	The blog. Posts appear at /journal .	Admin
Media /admin/media	One shared library for all images and files.	Admin
Before & after /admin/gallery	Result photo pairs, tagged by treatment, with consent flags.	Admin

Edit and publish a page ADMIN

You can draft freely; only people with publish permission make it live.

1. Open </admin/pages> and open the page, or press **New page**.
2. Add or rearrange sections by dragging. Edit text and images in place.
3. Press **Preview** to see it as visitors will. When happy, press **Publish**.

Done when: the live page shows your changes.

BEFORE & AFTER PHOTOS

Only upload result photos where the client has signed consent for their images to be shown. Tag each pair with the treatment so it appears on the right page.

09 K Academy — the training platform

A full training academy inside the platform: market courses, enrol students, deliver theory and quizzes online, run practical days and live classes and issue certificates.

Screen	What it is for	For
Courses /admin/academy	The course catalogue and cohorts — levels, prices, dates, capacity.	Admin
Applications /admin/academy/enrolments	The enrolment pipeline. Accept applicants, take deposits, enrol them.	Admin
Trainees /admin/academy/students	Student accounts, progress, quiz scores and certificates.	Admin
Exam practice /admin/academy/practice	The question bank, mock papers and past papers.	Admin
Live classes /admin/academy/live-classes	Schedule online sessions and track attendance.	Admin
Careers /admin/careers	Post jobs and manage applicants for the clinic and academy.	Admin

Open a course for enrolment

ADMIN

1. Open </admin/academy> and open the course, or press **New course**.
2. Set the level, price, learning outcomes and accreditations.
3. Add a cohort with start and end dates, a cap on numbers and a location.
4. Make sure the lessons are published before you let people enrol. Save.

Done when: the course shows on </academy> with an Enrol button.

Enrol an applicant

ADMIN

1. Open </admin/academy/enrolments> and open the application.
2. Review their details and press **Accept**.
3. Take the deposit (instalments are supported) and confirm the place.

Done when: the trainee can sign in to the portal and start the course.

Trainees learn in a guided, bite-size format with a friendly on-screen guide, quizzes, points, badges and streaks, on phone or desktop. They can sign in with Face ID or a fingerprint. Content grows automatically through a standing job, so the course library keeps expanding without manual work.

10 Operations

Keep the clinic staffed, stocked, safe and consistent — rotas, inventory, suppliers, procedures, forms, devices and the end-of-day close.

Screen	What it is for	For
Schedules /admin/schedule	Staff hours, breaks, rooms, equipment and clinic closures. Links to Google Calendar if enabled.	Admin, Front desk
Session insights /admin/reports/sessions	How long appointments really take and where time is lost.	Admin
Inventory /admin/inventory	Stock with cost, expiry and usage. Items expiring within 90 days are flagged.	Front desk, Clinician
Reorder /admin/reorder	Low-stock list and purchase orders.	Front desk
Suppliers /admin/suppliers	Vendor contacts and bills (links to Xero).	Admin
SOPs /admin/sops	Step-by-step procedures per treatment, with sign-off.	Admin, Clinician
Consent /admin/consent	Consent form templates and signed-form history.	Admin, Clinician
Health forms /admin/health-forms	Medical intake questionnaires and completed responses.	Admin, Clinician
Devices /admin/devices	Card readers, screens, kiosks and printers.	Admin
Day close /admin/day-close	End-of-day cash-up, stock check and shutdown checklist.	Front desk
Facility /admin/facility	Floor plans, equipment guides and where things are kept.	All staff

Receive a stock delivery

FRONT DESK

CLINICIAN

1. Open `/admin/inventory` and find the item, or add it.
2. Press **Receive stock** and enter the quantity, batch number, expiry date and cost.
3. Save. The stock level goes up and the expiry is tracked.

Done when: the item shows the new quantity and a future expiry date.

Send a consent form before treatment

FRONT DESK

CLINICIAN

1. Open the client's booking.
2. Choose the right consent template (for example "Laser consent") and press **Send for signature**.
3. The client gets a secure link, reads it, ticks the boxes and signs.

Done when: the signed form shows against the client, dated and locked.

Run day close

FRONT DESK

The end-of-day ritual. Do it before leaving.

1. Open `/admin/day-close`.
2. Mark any in-progress treatments complete.
3. Count the cash and card takings and enter them to reconcile.
4. Do the stock check and tick off the shutdown list (clean, lights, alarm).
5. Submit to lock the day.

Done when: the day shows as closed and reconciled.

11 Marketing

A marketing department inside the platform: plan campaigns across channels, see what works, and let routine follow-ups run themselves.

Screen	What it is for	For
Marketing hub <code>/admin/marketing</code>	Overview of revenue, bookings, conversion and new clients, with links to every tool.	Admin
Campaigns <code>/admin/marketing/campaigns</code>	Email, SMS and paid campaigns with AI copy help and scheduling.	Admin
Performance <code>/admin/marketing/performance</code>	Which sources and campaigns bring revenue, plus a 90-day forecast.	Admin
Audiences <code>/admin/marketing/audiences</code>	Reusable client segments with live size counts.	Admin
Email <code>/admin/marketing/email</code>	Newsletters and bulk email, with opens and clicks.	Admin
Templates <code>/admin/marketing/templates</code>	Preview every client email the system sends.	Admin
Automations <code>/admin/automations</code>	Hands-off journeys: birthdays, post-treatment follow-ups, win-backs.	Admin
A/B testing <code>/admin/marketing/ab</code>	Test two versions of a page to see which converts better.	Admin
Insights <code>/admin/marketing/insights</code>	Click heatmaps, scroll depth and session replays.	Admin
Brand kit <code>/admin/brand</code>	Logos, colours, fonts and tone, used across pages and emails.	Admin
Connections <code>/admin/marketing/connections</code>	Connect Google, Meta and TikTok ad accounts.	Admin
QR codes <code>/admin/qr</code>	Printable QR codes with scan tracking, including kiosk codes.	Admin

Send an email campaign

ADMIN

Sending needs the campaigns.send permission. Only email clients who opted in.

1. Open `/admin/marketing/campaigns` and press **New campaign**.
2. Pick an audience segment, write the subject and body (use the AI suggestions if helpful), and choose a template.
3. Send a test to yourself first.
4. Schedule a send time or press **Send now**.

Done when: the campaign shows as sent, with opens and clicks updating over the next hours.

CONSENT MATTERS

Marketing email and SMS only go to clients who agreed to receive them. Never add people from outside lists. The platform suppresses anyone who bounces or complains automatically.

12 Finance

Take payment, see every transaction, plan cash, and run the books with the right controls.

Screen	What it is for	For
Till / POS /admin/pos	Ring up treatments and products, take card or cash, print receipts, refund.	Front desk
Orders /admin/orders	Every sale and receipt. Filter, download and refund.	Front desk, Admin
Cashflow /admin/cashflow	Cash reserves and a forward forecast.	Admin, Owner
Reports /admin/reports	Revenue by period, by clinician and by service; margins and costs.	Owner, Admin
Financial controls /admin/finance/controls	VAT and tax settings, refund policy, audit locks, Xero link.	Owner

Take a payment at the till

FRONT DESK

1. Open </admin/pos>.
2. Search and add the treatment or product to the sale.
3. Apply any discount, then press **Charge** and take card or cash.
4. Offer a printed or emailed receipt.

Done when: the sale shows in Orders and the takings update day close.

FINANCE IS LOCKED BY DEFAULT

Reports stay locked until unlocked at </admin/finance/unlock>, which is rate-limited on purpose. Only finance roles see money figures. The owner holds the controls for VAT, refunds and audit locks.

13 Administration

Run the platform itself: launch checks, system health, the issues board, staff accounts, security, the audit log, site settings and integrations. Most of this is owner territory.

Screen	What it is for	For
Go live /admin/go-live	The pre-launch checklist to point the domain and switch payments live.	Owner
Status /admin/status	Platform health and uptime.	Owner, Admin
API health /admin/api-health	Green/red checks for Stripe, email, AI, Xero and more.	Owner, Admin
Build & issues /admin/build	Bug tracker and backlog; reported problems land here.	Admin, Owner
Contractors /admin/contractors	Check-in and tasks for visiting workers.	Admin
Staff & access /admin/staff	Add people, set roles and fine-tune permissions.	Owner
Security /admin/security	2FA policy, sessions, key health and threat monitoring.	Owner
Activity log /admin/activity	Who did what, when — the audit trail.	Owner, Admin
Site & globals /admin/site	Header, footer and navigation for the public site.	Admin
Locations /admin/locations	Set up and manage multiple clinic branches.	Owner
SEO /admin/seo	Search health, page titles and descriptions, on-site search.	Admin
Redirects /admin/redirects	Forward old links to new ones to protect search ranking.	Admin

Screen	What it is for	For
Integrations /admin/integrations	Connect and check third-party services.	Owner
Credentials /admin/settings/credentials	Store and rotate API keys inside the app.	Owner
Settings /admin/settings	Clinic-wide preferences and feature toggles.	Owner

Add a new team member

OWNER

1. Open </admin/staff> and press **Add staff**.
2. Enter their name and work email and choose a role (for example Front desk or Clinician).
3. Adjust individual permissions only if they need more or less than the role default.
4. Save. They get an email to set their password.

Done when: the person appears in the staff list and can sign in.

Remove access when someone leaves

OWNER

1. Open </admin/staff> and open their profile.
2. Press **Deactivate**.
3. Open </admin/security> and force sign-out of all sessions.

Done when: they can no longer sign in and existing sessions are ended.

14 The public website and booking flow

What clients see, and what you do behind it. The site turns visitors into bookings; the booking flow saves a card securely and only charges when the service is delivered.

THE CLIENT'S JOURNEY TO A BOOKING

- They browse treatments and prices, or use the treatment finder quiz at </treatment-finder> for a recommendation.
- They start a booking at </book>, pick a treatment, date and time, and sign in or create a free account (new clients get a welcome discount).
- They save a card securely. No money is taken then — only when the treatment is done, with free cancellation up to 24 hours before.
- They get a confirmation email with a calendar invite and a link to manage the booking themselves.

WHAT YOU WATCH AND DO

- Confirm new requests and consultation enquiries promptly from </admin/consultations> and </admin/bookings>.
- Chase failed payments: the client gets an automatic recovery email; if it is still unpaid after a couple of days, call them.
- Send health and consent forms before the appointment so the clinician is ready.
- After treatment, the system asks the client for a review automatically. Keep an eye on new ones in </admin/reviews>.

IF BOOKING LOOKS DOWN

If the database is briefly unreachable, the booking page shows a "please call us" message rather than an error, so you can still take the booking by phone and enter it in the admin.

15 The kiosk and in-clinic screens

Screens that work for you in the clinic and the window — a self-serve skin and smile check, and live room displays.

THE SKIN & SMILE KIOSK

A screen in the window or reception shows a QR code. A passer-by scans it, takes a selfie on their own phone, and gets a friendly skin and smile read-out with suggested treatments and a link to book. The photo is handled securely and deleted automatically after 30 days.

Set up and check the kiosk

ADMIN

FRONT DESK

1. Mount the screen and point it at </kiosk/display> (find the link and QR under </admin/qr>).
2. Check the QR is on screen and the WiFi is stable each morning.
3. If the screen freezes, reload the page or power-cycle the device.

Done when: the window screen shows the live QR and scanning opens the check on a phone.

Small screens outside treatment rooms show the room, the current client’s first name only, the treatment and the time, plus what is next. They refresh by themselves. Generate a screen link per room under Devices in Operations.

16 The client portal

What clients do for themselves once they have an account, which keeps work off the front desk.

Client screen	What they can do
Dashboard /account	See their next appointment, points balance and personal offers.
Appointments	View, add to calendar, reschedule or cancel within the rules.
Health forms	Complete medical questionnaires before a visit.
Invoices	Download receipts and invoices.
Rewards	Track points, find their referral link, redeem points off a visit.
Gift cards	Add a gift code to their balance.
Profile	Update details, marketing choices, and request a data export or deletion.

Most of this is self-service. Your job is to make sure forms are completed before treatment and to help anyone who calls in stuck.

17 Consent, before-photos and clinical safety

The records that protect the client, the clinician and the business. Treat these as non-negotiable before any treatment.

- Consent: send the correct consent form before treatment. The client signs on a secure page; the signed record is stored encrypted and cannot be altered.
- Health forms: the client completes their medical history before the visit. The clinician reads it from the clinical record.
- Before-photos: capture required laser before-photos through the platform, never on a personal phone. They are stored encrypted with the clinical record.
- Age policy: age-restricted treatments and products are checked at the point of booking or sale. No ID images are stored.

NO TREATMENT WITHOUT CONSENT

A booking should not be completed until the matching consent is signed and the health form is done. If you are unsure which form applies, ask the clinician before proceeding.

18 Owner: APIs, tokens and webhooks

The platform talks to outside services and to itself through a handful of addresses. Each is protected by a secret only you hold. You will rarely touch these once set, but here is what they are.

Address	What it does	Protected by
/api/cron/daily	Runs the nightly jobs: campaigns, loyalty, retention cleanup, syncs.	CRON_SECRET
/api/cron/dispatch	Sends scheduled email through the day.	CRON_SECRET
/api/build/queue	The work queue routine sessions read and log findings to.	BOARD_QUEUE_TOKEN
/api/stripe/webhook	Stripe tells the platform a payment succeeded or failed.	Stripe signature
/api/webhooks/resend	Email opens, clicks and bounces come back here.	Resend signature
/api/integrations/yay	Phone calls and voicemails are logged here.	YAY_WEBHOOK_SECRET
/api/health	A simple "is it up" check. Public, no secret.	None

WHERE THESE ARE REGISTERED

For Stripe, Resend and yay.com, paste the platform address into that provider's dashboard as the webhook target, then copy their signing secret back into your hosting settings. The Go-Live guide walks through each one.

19 Owner: environment variables and secrets

These are the keys that switch each service on. They live in your hosting settings (Vercel → k-clinics → Settings → Environment Variables) or in `/admin/settings/credentials`. Keep them out of email and chat.

CORE PLATFORM (REQUIRED)

Key	What it is for
<code>DATABASE_URL</code>	The database connection. The most sensitive secret you hold.
<code>ADMIN_JWT_SECRET</code>	Signs staff logins. Change it to sign everyone out.
<code>CLIENT_JWT_SECRET</code>	Signs client-portal logins. Keep different from the admin one.
<code>ACADEMY_JWT_SECRET</code>	Signs academy trainee logins. Keep different again.
<code>NEXT_PUBLIC_SITE_URL</code>	Your live web address, used in links and emails.

HEALTH DATA ENCRYPTION (REQUIRED IF STORING HEALTH DATA)

Key	What it is for
<code>HEALTH_ENCRYPTION_KEY</code>	Locks health records. Never change it once data exists, except through the proper rotation steps.
<code>HEALTH_HMAC_KEY</code>	Proves health records have not been tampered with.

SERVICES YOU SWITCH ON AS NEEDED

Service	Keys	Used for
Stripe	<code>STRIPE_SECRET_KEY</code> , <code>NEXT_PUBLIC_STRIPE_PUBLISHABLE_KEY</code> , <code>STRIPE_WEBHOOK_SECRET</code>	Card payments and deposits
Resend	<code>RESEND_API_KEY</code> , <code>EMAIL_FROM</code> , <code>RESEND_WEBHOOK_SECRET</code>	All email
Twilio	<code>TWILIO_ACCOUNT_SID</code> , <code>TWILIO_AUTH_TOKEN</code> , <code>TWILIO_FROM</code>	SMS reminders
Anthropic	<code>ANTHROPIC_API_KEY</code>	Kiosk AI, live chat help, marketing copy
Vercel Blob	<code>BLOB_READ_WRITE_TOKEN</code>	Image and video uploads
Google	<code>GOOGLE_CLIENT_ID</code> , <code>GOOGLE_CLIENT_SECRET</code>	Calendar sync, reviews, business profile
Xero	<code>XERO_CLIENT_ID</code> , <code>XERO_CLIENT_SECRET</code>	Accounting
TrueLayer	<code>TRUELAYER_CLIENT_ID</code> , <code>TRUELAYER_CLIENT_SECRET</code>	Live bank balance
yay.com	<code>YAY_WEBHOOK_SECRET</code>	Call logging and click-to-dial
Cloudflare	<code>TURNSTILE_SECRET_KEY</code> , <code>NEXT_PUBLIC_TURNSTILE_SITE_KEY</code>	Bot protection at login
Upstash	<code>UPSTASH_REDIS_REST_URL</code> , <code>UPSTASH_REDIS_REST_TOKEN</code>	Rate limiting and speed
Automation	<code>CRON_SECRET</code> , <code>BOARD_QUEUE_TOKEN</code>	Nightly jobs and the work queue

MAKE A STRONG SECRET

For any token or JWT secret, run `openssl rand -base64 32` and paste the result. Store a copy in a password manager, never in a note or a doc. Keep an offline backup of `HEALTH_ENCRYPTION_KEY` in particular.

20 Owner: data retention

The platform deletes old data on a schedule, run by the nightly job. This is what is removed and when. Anything not listed is kept until you delete it.

Data	Kept for	Then
Kiosk selfies and results	30 days	Deleted automatically
Website session replays	90 days	Deleted automatically
Failed-login security events	90 days	Deleted automatically
Heatmap clicks and scrolls	180 days	Deleted automatically
Loyalty points	12 months from earning	Expired
Call recordings and transcripts	~13 months	Number and length kept; recording and transcript scrubbed
Signed consent forms	8 years	Deleted (UK clinical norm)
Before-photos	8 years	Deleted (UK clinical norm)

YOUR DECISION TO MAKE

There is no automatic deletion yet for client profiles, bookings, consultations or audit logs — they are kept until removed by hand. Decide a policy (for example, anonymise clients with no visit for five years) and ask for it to be built. Note it in your privacy policy either way.

21 Owner: GDPR and data protection

The clinic handles personal and health (special-category) data under UK GDPR. Health records are encrypted, and there are tools to answer access and deletion requests. Here is what to do, and the gaps to be aware of.

CONSENT

- Marketing email and SMS only go to clients who gave clear, opt-in consent. Keep a note of when and how each person agreed.
- The cookie banner is opt-in with no pre-ticked boxes, and reject is as easy as accept.
- For health questionnaires, show a privacy notice and capture separate consent for processing health data, kept apart from marketing consent.

ACCESS REQUESTS (A CLIENT ASKS FOR THEIR DATA)

Answer a subject access request OWNER

1. Open the client at `/admin/clients` and choose the export option (a senior role plus a passkey step is required).
2. The platform produces a readable file of their records, including health data, decrypted for the response.
3. Send it to the verified client securely, within one month.

Done when: the client has their data and the export is recorded in the activity log.

ERASURE (A CLIENT ASKS TO BE DELETED)

Erase a client's data OWNER

1. Open the client at `/admin/clients` and choose the privacy / erase option.
2. Confirm. The platform pseudonymises the profile and hard-deletes health records, photos, consents, reviews and messages in one step, keeping only the minimum billing facts the law requires.

Done when: the client shows as erased and the action is in the audit log.

CALL RECORDING AND OTHER DUTIES

- Tell callers their call may be recorded (a line in the phone greeting). This is a legal requirement.
- Register with the ICO as a data controller if you have not already.
- If personal data is ever exposed, assess the risk and report to the ICO within 72 hours where required.

KNOWN GAPS TO CLOSE

A recent audit flagged items still to do: a stored timestamp and source on each marketing opt-in; a log when clinical data is viewed routinely (not only on export); retention rules for chat, referral and waitlist data; and finishing erasure cover for call records. Track these on the Build board.

22 Owner: security baseline

The platform ships with strong defaults — encrypted health data, signed logins, brute-force limits, 2FA, security headers. Your job is to switch on what needs switching on and keep good habits.

BEFORE YOU GO LIVE

- Generate fresh secrets for every key (do not reuse test values), and store them in a password manager.
- Turn on 2FA for your own account and add a passkey. Require 2FA for admins and clinicians.
- Point the Stripe, Resend and yay webhooks at the platform and paste their signing secrets back in.
- Turn on your hosting firewall and add rate limits to the login addresses.
- Confirm the database has automatic nightly backups, and test that a backup actually restores.
- Use a read-only database login for any data audit, never the main one.

EVERY MONTH

- Review who has access at `/admin/staff` and remove anyone who has left.
- Check `/admin/security` for lockouts and unusual login attempts.
- Confirm the nightly job ran (the status page shows the last run).
- Skim the activity log for exports and deletions.

NEVER DO THIS

- Share an admin login by email, chat or a shared document.
- Change `HEALTH_ENCRYPTION_KEY` without following the rotation steps first — historic health records would become unreadable.
- Put a webhook secret in a web address; it belongs in the header or body.

23 On the roadmap

Planned features, listed so the team knows what is coming. These are not live yet. Order and timing can change.

Coming feature	What it will do
Role-based dashboards SOON	A home screen built around each job — clinicians see prep and rooms, reception sees front-of-house, developers see build and CI.
Exceptional appointment view SOON	A guided, step-by-step appointment from check-in to leaving, with optional voice notes that draft the clinical record for the clinician to edit and the client to sign.
In-app bookkeeping SOON	Payroll, suppliers, bills and receipts in the admin, linked to Xero.
Storefront QR kiosk SOON	The window Skin & Smile kiosk, with share-to-claim discounts and storefront-screen integration.
Two-way SMS SOON	Hold a real text conversation with clients, not just one-way reminders.
Smart waitlist fill SOON	Automatically offer a cancelled slot to the best-matched waiting client.
Memberships & subscriptions SOON	Recurring plans with member benefits and billing.
Photo progress timelines SOON	A dated photo history of a client's results over a course of treatment.
Payment plans SOON	Built-in instalments for higher-cost treatments and courses.
Clinician mobile app SOON	An installable app for practitioners on the move.
No-show prediction SOON	A flag on bookings likely to no-show, so you can confirm them.
Security certifications SOON	Cyber Essentials, NHS DSPT, then ISO 27001 and SOC 2 over time.

The academy course library also grows on its own: a standing job adds new bite-size training content regularly, so trainees keep getting more without anyone authoring by hand.

24 Glossary and where to get help

Plain definitions for the words that come up, and who to ask.

Word	Means
Admin	The staff side of the platform at <code>/admin</code> .
Permission	A switch that lets a role do one thing (for example, see clinical records).
2FA	A second login step, like a code or your fingerprint.
Passkey	Signing in with Face ID or a fingerprint instead of a password.
Webhook	A message another service sends the platform when something happens.
Environment variable	A secret key, set in hosting, that switches a service on.
Cron / nightly job	A task that runs on a schedule, such as the overnight cleanup.
SAR	Subject access request — a client asking for a copy of their data.
NPS	A simple 0-10 score of how likely clients are to recommend you.

GETTING HELP

- Something broken on a screen: use **Report a problem** (bottom-right) so it is logged with a screenshot.
- A "how do I" question: check this manual first, then ask the owner or admin.
- A client data request or anything legal: route it to the owner.
- Support email: `support@kclinics.co.uk` .

KEEP THIS CURRENT

This manual is generated from the platform. When features change, regenerate it with `node docs/staff-manual/build-pdf.cjs` so the team always has the right version.